Security & Privacy Plan — Leish! Aesthetic Marketplace

Version: 1.0 · **Date:** 2026-10-12 · **Status:** Required engineering baseline

Security objectives

Protect account credentials, booking/contact information, provider management actions and third-party tokens. Preserve useful browsing and booking during AI outages without weakening authorization.

Threat model

Threat	Asset	Control
Credential stuffing	Accounts	bcrypt, auth rate limit, generic login errors
Broken object authorization	Bookings/listings	JWT plus ownership middleware
PII enumeration	Emails/bookings	Auth-scoped reads and sanitized responses
Secret exposure	JWT/Gemini/Maps keys	Environment secrets, no client Gemini key, restricted M
Prompt/model failure	User trust	zod output parsing, timeout, deterministic fallback
Review abuse	Reputation	Completed-booking eligibility and rate limiting
Data loss	Bookings/catalog	Durable adapter, backups/migration, atomic writes
XSS/injection	Browser/session	Output encoding, validation, Helmet/CSP
DoS	API availability	Route-specific rate buckets, body limit, timeouts

Required controls

1. Production must fail fast when `JWT_SECRET` is missing; no development fallback may run in production.
2. Passwords must be bcrypt hashes and never appear in API responses or logs.
3. Gemini credentials must remain server-side and must not use a `VITE_` prefix.
4. Every mutation must validate input on the server and check resource ownership.
5. Booking reads must require authentication and scope by the authenticated client or provider identity.
6. Logs must exclude passwords, JWTs, cookies, access tokens, raw prompts containing PII and full request bodies.
7. Cookies/tokens, if introduced, must use secure transport and appropriate expiry/rotation controls.
8. Dependencies and deployment configuration must be reviewed before production release.

Privacy principles

- Collect only contact and booking data needed to fulfill a request.
- Explain why phone, email, venue and notes are collected before submission.
- Do not expose client email/phone in public listing or review responses.
- Do not send booking PII to Gemini unless the product explicitly requires it and the data path is approved.
- Retain bookings and audit data only for an agreed business period; support deletion/export requirements when the operational policy is defined.
- Obtain consent before enabling analytics or optional Google Workspace scopes.

Incident response

1. Triage: record deployment, route, timestamp, request ID and impact without copying sensitive payloads.
2. Contain: disable affected route/key, rotate compromised secret, or roll back the deployment.
3. Eradicate: patch authorization, validation or dependency issue and add a regression test.
4. Recover: deploy through the runbook, verify login/booking/provider smoke flows, and restore data if required.
5. Learn: document root cause, affected records, notification obligations and prevention work.

Security acceptance

Release is blocked until production secrets are externalized, ownership checks pass, PII reads are scoped, the authz matrix is tested, and the selected persistence backend has a verified backup/restore story.